

Merchant Confirmation - Security Audit / Integration Checklist

We confirm that the following points have been implemented and are ready for the Security Audit / Bank Testing process.

Merchant: Corp Culture
Website: <https://corpculture.in>
Gateway: HDFC SmartGateway (UAT)
Merchant ID: SG5903
Date: 12 September 2026
Return URL: <https://corpculture.in/shipping/payment-return>
UAT Base URL: <https://smartgateway.hdfcuat.bank.in>

A. Payment Process Flow

Step-by-step screenshots (home to success, with URL bar)	READY	Screenshots will be shared separately as requested.
Unique Customer ID for every customer	YES	Unique customer_id per logged-in user (alphanumeric, max 20).
Do not use UDF2 parameter	YES	UDF2 is not used in session/create payload.
Order number & amount match HDFC page on final response	YES	Server-priced amount stored in DB; Status API amount validated before fulfillment; success page shows same values.
Response page shows Order number, Amount, Success message	YES	Success page displays Order number, Payment order ID, Amount (INR), Success message, and Receipt number.

Order ID Format Requirements

Length less than 21 characters	YES	Order ID length is maximum 20 characters.
No special characters	YES	Alphanumeric only (A-Z, 0-9).
Alphanumeric allowed	YES	Implemented.
Non-sequential	YES	Generated using timestamp + random segment (not a counter).

B. Order Status API Logs

Share Order Status API response logs for verification	YES	Every verify call stores Status API snapshot in DB (lastGatewayResponse), including dual-inquiry results. Logs available for audit.
---	-----	---

C. Security Audit Process Confirmations

1. Maintain DB to store transaction details and status	YES	Sessions store hdfcOrderId, amount, status, gateway status, Status API response, refunds, receipt number.
2. Payment confirmation based on DB status	YES	Success/failure based on DB status after server-side Status API verification, not redirect params alone.

3. Ready for multiple test transactions during audit	YES	UAT environment and test access will be available for repeated transactions.
4. Keep login credentials available until audit complete	YES	Credentials will be shared securely and kept active until audit closure.
5. Do not clear DB records until audit completed	YES	Transaction/session records will not be cleared during audit period.
6. UAT setup identical to production setup	YES	Same application code/flow as production; only UAT endpoints/credentials differ.
7. Mandatory dual inquiry - Status API in response	YES	Status API called twice on verify; fulfillment only when both responses match (status + amount).
8. Implement attached Audit Checklist	YES	All checklist items below are implemented.

Note: Testing is performed on merchant UAT. Only test credentials will be used. Test transactions/orders will NOT be honored as live business orders.

Security Audit Checklist (Anti-Tampering)

1. Unique order ID generation	YES	Unique HDFC order_id per payment with unique DB index.
2. Request tampering protection	YES	Amount calculated on server and stored in DB; client amount not trusted; re-checked vs Status API.
3. Response tampering protection	YES	HMAC validation with Response Key when signature present; Status API bound to session order_id.
4. URL redirection validation	YES	Return/redirect only to allowlisted frontend origins / production domain.
5. Duplicate entry validation	YES	Unique session per hdfcOrderId; existing paid/failed order reused - no duplicates.
6. Receipt generation	YES	Unique receipt number per payment session shown on success response page.
7. Valid and secure SSL	YES	Production site and return URL use HTTPS; gateway APIs are HTTPS.

Technical Summary

- 1) Payment initiation: Server creates SmartGateway session with unique order_id, unique customer_id, server-calculated amount, and HTTPS return URL.
- 2) Customer pays on HDFC payment page.
- 3) Return handling: Merchant return page receives order_id (and signature params if signed response enabled).
- 4) Dual inquiry: Backend calls Order Status API twice and compares results.
- 5) Confirmation: Order marked Paid only if Status API confirms success AND amount matches DB session.
- 6) Customer UI: Success page shows Order number, Amount, and Success message from verified DB/Status API data.

Attachments Available on Request

1. Step-by-step payment screenshots (URL bar visible)
2. Sample Order Status API response logs (success / failure / pending)
3. Sample success-page screenshot showing Order number + Amount + Success message
4. Test login / UAT access details (shared securely, not in email body)

Declaration

We confirm that the above points are implemented on our UAT setup and we are ready for the Security Audit / Bank Testing process.

Authorized person: _____

Designation: _____

Contact / Email: _____

Signature / Date: _____